

ACME CORPORATION - ACCESS CONTROL POLICY

Version 3.0 | Effective Date: March 1, 2025

SECTION 1: PURPOSE AND SCOPE

This policy defines requirements for controlling access to ACME Corporation systems, applications, and data. It applies to all employees, contractors, and third parties who access corporate resources.

SECTION 2: PRINCIPLE OF LEAST PRIVILEGE

All access rights must be granted on a need-to-know and least-privilege basis. Users must only be granted the minimum access necessary to perform their job duties. Privileged access (admin rights) must be approved by the employee's manager and the IT Security team before being provisioned.

SECTION 3: ACCESS REQUEST AND PROVISIONING

Access to systems must be requested via the IT Service Portal using the Access Request Form (ARF-001). Requests must be approved by the data owner and the employee's direct manager. Access must be provisioned within 3 business days of approval. All access grants must be documented in the Identity and Access Management (IAM) system.

SECTION 4: MULTI-FACTOR AUTHENTICATION

Multi-factor authentication (MFA) is mandatory for all remote access to corporate systems, all cloud-based applications, and all privileged accounts. Acceptable MFA methods include TOTP authenticator apps (Google Authenticator, Microsoft Authenticator) and hardware security keys (FIDO2/WebAuthn). SMS-based MFA is not permitted for privileged accounts due to SIM-swapping risks.

SECTION 5: ACCESS REVIEWS

Access rights for all users must be reviewed every 90 days by the relevant data owner. Privileged access must be reviewed every 30 days. Any access that is no longer required must be revoked within 5 business days of the review decision. Results of access reviews must be logged and retained for 3 years.

SECTION 6: ACCOUNT TERMINATION

Upon employee termination, all system access must be revoked within 4 hours of HR notification. For involuntary terminations, access must be revoked immediately at the time of the termination meeting. Shared credentials known to the terminated employee must be rotated within 24 hours. IT must confirm revocation in writing to HR and the employee's manager.

SECTION 7: THIRD-PARTY ACCESS

Third-party vendors requiring access to corporate systems must sign a Data Processing Agreement (DPA) before access is granted. Third-party access must be time-limited, not exceeding 90 days, and must be renewed explicitly. All third-party sessions must be logged and monitored in real time via the Privileged Access Management (PAM) tool.

SECTION 8: COMPLIANCE AND ENFORCEMENT

Violations of this policy may result in disciplinary action up to and including termination of employment or contract. Access control compliance is audited monthly by the Information Security team and reported to the CISO quarterly.